

Open-Weight LLM Threat Cook Book

싸이월드 전 대표가 알려주는

보안 제약이 풀린 오픈웨이트 AI 해킹과 방어 레시피

GLM · KIMI 사이버 보안 특화 버전 위협 분석과 방어 요리법

공세형 모델 2계열 · 검증된 오픈소스 툴 6종 · 모의 해킹 레시피 7종 · 로그 기반 방어 솔루션

"심연을 바라볼 때 그 심연에 빠져서는 안 된다."

김호광 Dennis Kim

vibequant.cc · github.com/gameworkerkim · gameworker@gmail.com

법적·윤리적 경고 — 본 문서는 방어·위협 인텔리전스·정책 검토를 위한 분석 자료다. 모든 툴·명령의 사용은 **격리된 연구 환경과 서면 범위 승인(scope authorization)** 하에서만 허용된다. 타인 시스템 무단 접근은 한국 정보통신망법 제48조, 미국 CFAA(18 U.S.C. §1030), 영국 Computer Misuse Act 1990 등에 따라 형사처벌 대상이다. 법적 고지·승인 양식은 14장과 부록 C, 격리 환경 구성은 부록 B를 참조하라.

인공지능을 이용한 해킹 기법을 이해하는 것은 공격자가 어떤 무기와 속도로 시스템을 공략할 수 있는지에 대한 이해의 단초가 되었으면 한다. 예를 들어 생성형 AI는 피싱 메일의 문법·맥락·언어를 자연스럽게 만들고, 딥페이크 음성·영상은 전화·영상 통화 기반 사회공학의 신뢰를 훔치며, 자동화된 코드 생성·스캐닝·퍼징은 취약점 탐색과 공격 시나리오 작성의 속도를 높인다. 이는 방어자가 공격자의 언어와 속도를 먼저 이해해야 한다는 뜻이지, 법에서 벗어나 관련 기관 승인 없는 공격을 연습하라는 뜻이 아니다.

2000년대 이전/초만 해도 시스템 침해 사고를 일으킨 이가 그 이력 때문에 오히려 보안 업계에 초빙되는 사례가 있었다. 케빈 미트닉 같은 인물이 대표적이다. 그는 범죄 이력 후에도 보안 컨설턴트·저술가로 활동했다. 그러나 지금은 다르다. 정보통신망법 제 48조, 미국 CFAA(18 U.S.C. §1030), 영국 Computer Misuse Act 1990 등은 무단 접근을 명백한 범죄로 규정한다. 기업·기관은 신원조회, 보안면허, 윤리검증을 거치며, 범죄 이력은 취업 제한으로 이어진다. 이제 '해커 출신'은 더 이상 면허가 아니라 범죄자 취급만 받을 뿐이다.

기술의 발전과 보안 업계의 인식은 시대의 흐름에 따라 바뀐다. 버그바운티, 레드팀, CTF, 책임 있는 공개(coordinated disclosure)는 합법적이고 윤리적인 경로다. 반면 승인 없는 스캔·침투·AI 악용은 연구가 아니라 범죄 행위일 뿐이다.

미래를 망치지 마라.

심연을 들여다보되 심연에 빠지지 말라는 경고를 남긴다. 그리스·로마 신화의 이카루스는 날개를 만든 기술의 힘에 취해 태양에 가까이 날아올랐고, 밀랍 날개가 녹아 추락했다. 프로메테우스가 훔친 불은 인류의 등불이 될 수도, 남의 집을 태우는 방화가 될 수도 있다. 판도라의 상자도 경고한다. 호기심 자체는 죄가 아니지만, 열어서는 안 될 것을 여는 순간 책임은 현실이 된다.

저자 소개

김호광 (Dennis Kim)

- 前 싸이월드 대표 — 한국의 대표 소셜 플랫폼, 3,500만 회원
- 게임 보안, 소셜 플랫폼, 블록체인 분야 28년 이상의 개발 경력
- Microsoft Azure MVP 9년 연속 (2015-2023)
- 사이버 위협 인텔리전스(CTI) · AI 기반 퀀트 투자 · Web3를 연구하는 독립 연구자
- 원본 취약점 연구: 텔레그램 0-click RCE (ZDI-CAN-30207, CVSS 9.8 Critical)
- 한국어·영어·일본어·중국어 4개 국어 콘텐츠 발행
- 오픈 리서치 플랫폼 VibeQuant 운영: AI 퀀트 · 사이버 위협 인텔리전스 · Web3, 투자 칼럼 380여 편
- 공개: vibequant.cc

싸이월드에서 수천만 명이 글을 쓰고, 공유하고, 퍼뜨리는 장면을 가장 가까이에서 지켜봤다. 보안에서도 마찬가지다. 무엇이 공격되고 무엇이 막아지는지, 그 차이는 대부분 "어떤 환경에서"와 "누가 먼저 움직이는가"에서 갈렸다. AI 시대에도 이 원칙은 변하지 않는다. 바뀐 것은 그 원칙이 실행되는 속도다.

이 책은 유료 강의나 멤버십이 아닌, 누구나 읽을 수 있는 공개 문서로 배포한다. 지식은 나눌수록 세상을 조금 더 낮게 만든다고 믿기 때문이다.

원본 GitHub 저장소: [vibe-investing / Open-Weight-LLM-Threat-Analysis-and-Technical-Guide](https://github.com/vibe-investing/Open-Weight-LLM-Threat-Analysis-and-Technical-Guide)

서문: 위협도 레시피다

"정직한 이야기는 꾸밈없이 말할 때 가장 빨리 전해진다."

"An honest tale speeds best, being plainly told."

— 윌리엄 셰익스피어, 《리처드 3세》 4막 4장 (Richard III, Act IV, Scene IV)

보안 전문가가 아니면, 공격자의 세계는 마법처럼 보인다. 그러나 공격도 하나의 레시피가 있는 요리와 같다. 누구나 따라할 수 있는 절차의 조합이고, 그 절차를 알면 방어 조리의 조리법도 보인다. 공격자의 레시피를 모르는 방어자는, 맛을 보기 전에 불을 끌 수 없는 요리사와 같다.

이 책은 요리책의 형식을 빌렸다.

요리	위협 분석
재료	모델 · 가중치 · GPU 구성
손질	양자화 · ablation · 서빙 셋팅
양념	툴 · 프레임워크 · 코드
레시피	모의 해킹 시나리오
플레이팅	리포트 · CTI 산출물
간 보기	벤치마크 · 로그 검증
화재 경보	탐지 · 방어 통제
주방 규칙	법적 · 윤리적 고지

좋은 양념도 재료가 없으면 요리가 되지 않는다. 이 책의 원칙은 세 가지다.

- 1. 재료부터 정확히 안다.** 모델이 "무엇을 할 수 있는가"보다, 그 능력을 **누가 · 어떤 제약 없이** 쓸 수 있는가가 위협의 본질이다.
- 2. 양념보다 격리 환경이 먼저다.** 툴은 양날의 칼이다. 잘 설계된 격리 환경(다중 격리, egress 차단)이 선행되어야 한다.
- 3. 결과는 반드시 간을 본다.** LLM은 엑셀이지 신탁이 아니다. 벤치마크는 재검증하고, 공격을 전제로 로그에서 이상 징후를 찾는다.

문서 범위 및 작성 원칙

본 문서는 안전장치가 제거되었거나 공세적 사이버 작업을 차단하지 못하는 오픈웨이트 대형언어모델(open-weight LLM) 두 계열 — Zhipu AI(Z.ai)의 GLM 시리즈와 Moonshot AI의 KIMI 시리즈 — 의 공세형 변형을 위협 인텔리전스 및 보안 기술 관점에서 특성화하는 것을 목적으로 한다.

본 문서는 다음을 포함한다.

- 공세형/ablated 모델의 설치·배포 절차, 요구 GPU 구성, 런타임 셋팅 방법
- 공세적 에이전트 프레임워크 및 오케스트레이션 툴의 구성·설정 방법
- 오픈 소스 레드팀 툴(중국산 포함)의 실제 사용 예시·명령·워크플로우

- 방어 관점의 탐지·완화·대비 전략
- 방어자를 위한 LLM 오픈소스 로그 기반 이상 탐지 솔루션

출처 및 신뢰도 고지: 본 문서의 정량 수치(벤치마크, 파라미터 규모, 비용 추정 등)는 1차 자료 및 그 안에서 인용된 제3자 평가 (Anthropic, UK AISI/CAISI, Moonshot AI 자체 평가, Abliteration.ai 자체 평가, Vercel 분석)를 종합한 것이다. 이들 수치는 급변하는 영역이며 평가 주체마다 방법론이 상이하므로, 조직 차원의 의사결정에 활용하기 전 독립적 재확인이 필요하다. 특히 자체 평가(self-reported) 수치는 제3자 평가 대비 낙관 편향 가능성을 전제로 해석한다.

리스크 및 법률 고지: 본 문서는 보안 전문가를 위한 보안 테스트용이며, 격리된 보안 환경에서 모의 해킹을 권장한다. LLM의 경우 엔트로픽과 OpenAI의 사태처럼 격리된 환경을 이탈할 수 있기 때문에 잘 설계된 격리된 환경이 선행되어야 한다. 해커들의 해킹 기법, 이용 방식을 이해해야 우리는 안전한 사이버 보안 환경을 만들 수 있다.

심연을 바라볼 때 그 심연에 빠져서는 안 된다.

이 책을 읽는 법: 독자별 추천 코스

한 번에 다 읽을 필요는 없다. 자기 역할의 경로를 따라 한 주에 한 장씩 실습하는 것이 가장 빠르다.

독자	먼저 읽을 장	핵심 메뉴
보안 전문가 (레드/블루팀)	1 → 4 → 5 → 9	모의 해킹 레시피 + 탐지 포인트
학습자	1 → 2 → 3 → 5	재료(모델) 이해 → 격리 실습 레시피
정책·규제 담당자	1 → 11 → 13	위협 지형 + 규제 공백 + 수용 프레임
방어자 (CISO/블루팀)	9 → 10 → 14	"그래서 어떻게 탐지하는가" + 로그 기반 LLM 방어

AI 해킹 방어로 인해 시간이 없다면: 5장 모의 해킹 레시피와 10장 로그 기반 방어 솔루션만 먼저 읽어도 된다. 각 장의 세익스피어 명언은 장의 주제를 한 문장으로 요약했다.

목차

PART 0. 주방 준비

1장. 배경 — 왜 오픈웨이트가 위협 모델을 바꾸는가	10
-------------------------------	----

PART 1. 재료 — 공세형 모델

2장. GLM — '거절 없는' 재료의 손질법	12
---------------------------	----

3장. KIMI — 양념 없이 맵고, 우리 없이 탈출하는 재료	16
------------------------------------	----

PART 2. 양념과 조리 도구

4장. 검증된 오픈소스 LLM 보안 툴	22
-----------------------	----

PART 3. 메인 요리 — 실전 레시피

5장. 테스트용 모의 해킹 레시피 7종	25
-----------------------	----

PART 4. 간 보기 — 검증과 맛 평가

6장. GLM vs KIMI 비교 요약	29
-----------------------	----

7장. 생태계 및 비교 대상	30
-----------------	----

8장. 위협 지형 분석 — 공격자 경제학	31
------------------------	----

PART 5. 화재 예방 — 방어자의 주방

9장. 방어자 관점에서 탐지, 완화, 대비	33
-------------------------	----

10장. "그래서 어떻게 탐지하는가" — 방어자를 위한 LLM 로그 기반 솔루션	35
--	----

PART 6. 후식과 주방 규칙

11장. 규제, 정책 동향	41
----------------	----

12장. 종합 리스크 프로파일 및 결론	42
-----------------------	----

13장. 종합 평가 - 세 가지 수용 프레임	43
--------------------------	----

14장. 사용 시 주의 및 법적, 윤리적 고지	44
---------------------------	----

부록 (Appendices)

부록 A. 챗터별 레퍼런스 링크	45
부록 B. 격리 실습 환경 구성 가이드	46
부록 C. 법적 고지 심화 — 법조항·승인 양식·체크리스트	47
부록 D. 윤리적 의사결정 프레임워크	48
부록 E. 벤치마크 방법론 투명성 표	49
부록 F. 탐지 룰 실측 및 LLM 판정 우회 대응	50
부록 G. 용어집 (Glossary)	51

P A R T O

주방 준비

왜 오픈웨이트가 위협 모델을 바꾸는지, 요리를 시작하기 전에 불과 칼을 이해한다.

"사람은 때로 자기 운명의 주인이 된다."

"Men at some time are masters of their fates."

— 윌리엄 셰익스피어, 《줄리어스 시저》 1막 2장 (Julius Caesar, Act I, Scene II)

1장. 배경 — 왜 오픈웨이트가 위협 모델을 바꾸는가

"덴마크에 무언가 썩은 것이 있다."

"Something is rotten in the state of Denmark."

— 윌리엄 셰익스피어, 《햄릿》 1막 4장 (Hamlet, Act I, Scene IV)

1.1 핵심 위협 메커니즘

프론티어 폐쇄형 모델은 API 게이트웨이에서 거부(refusal) 안전장치, 사용량 모니터링, 계정 식별, 레이트 리미트가 중첩 적용된다. 반면 오픈웨이트 모델은 **가중치(weights)가 배포되는 순간** 이 통제층이 사실상 무력화된다. 위협의 본질은 모델의 "능력"이 아니라, 능력을 **누가·어떤 제약 없이** 사용할 수 있는가에 있다.

요리사의 식칼이 식당에서 요리를 할 때는 맛있는 요리를 만들지만, 그 칼이 잘못된 방향으로 휘돌릴 때 흉기가 될 수 있는 것처럼 오픈웨이트 모델은 상존하는 위험이 있다는 것을 이해해야 한다. 기술은 가치 중립적이다.

두 가지 무력화 경로가 존재한다.

1. **Abliteration (거부 방향 제거):** 모델 가중치에서 거부 응답을 유도하는 방향 벡터를 식별·제거하는 사후 가공 기법. 프롬프트 엔지니어링 없이도 유해 요청에 대한 거부율이 급감한다. GLM 계열이 이 경로의 대표 사례다.
2. **안전장치 자체의 부재/미비:** 애초에 공세적 사이버 작업을 차단하는 효과적 안전장치가 탑재되지 않은 경우. KIMI K3 계열이 이 유형으로 분류된다.

1.2 위협 지형에 주는 의미

- **재현 불가능성:** 폐쇄형 모델의 안전장치는 벤더가 패치할 수 있으나, 일단 배포된 오픈웨이트 복사본은 회수·롤백이 불가능하다.
- **감사 불가능성:** 로컬/온프레미스 추론 시 외부에서 사용 내역을 관측할 수 없어 사후 탐지가 어렵다.
- **진입비용 붕괴:** 후술할 ablation 비용 추정치는 조직화된 위협 행위자뿐 아니라 소규모 그룹의 접근도 가능함을 시사한다.

P A R T 1

재료 — 공세형 모델

GLM과 KIMI, 두 가지 공세형 재료의 성질과 손질법을 다룬다.

"오, 놀랍구나! 이곳에 어찌 이리 훌륭한 피조물들이 많은가!"

"O, wonder! How many goodly creatures are there here!"

— 윌리엄 셰익스피어, 《템페스트》 5막 1장 (The Tempest, Act V, Scene I)

2장. GLM — '거절 없는' 재료의 손질법

"지옥은 비었고, 악마들은 모두 여기에 있다."

"Hell is empty and all the devils are here."

— 윌리엄 셰익스피어, 《템페스트》 1막 2장 (The Tempest, Act I, Scene II)

2.1 개요

GLM-5.3(약 753B MoE)을 기반으로 한 공세형 변형은 주로 **가중치 수준의 ablation**을 거쳐 배포된다. 즉 모델 자체의 아키텍처·지식은 원본과 유사하나, 거부 행동만 선택적으로 제거된 형태다. GLM-5.3은 MoE + MLA + DeepSeek-sparse attention 구조를 채택하고 있으며, NVFP4 양자화 버전은 표준 vLLM으로 로드하면 바로 동작한다.

2.2 배포 형태

변형 유형	기반	양자화	배포 성격	크기
ABLITERATED-NVFP4	GLM-5.3 (753B)	NVFP4	로컬 배포용 가중치	195 GB
UNCENSORED-FP8	GLM-5.3	FP8	도메인 특화 태깅	756 GB
abliterated-large-v2	GLM-5.3	FP8	OpenAI 호환 API 엔드포인트	서비스형
EXL3 3.0BPW Abliterated	GLM-5.3	EXL3 3-bit	vLLM 서빙 레시피	약 280 GB

NVFP4 버전은 `dealignai/GLM-5.3-Flash-ABLITERATED-NVFP4` 로 Hugging Face에 공개되어 있으며, FP8 버전은 `dealignai/GLM-5.3-UNCENSORED-FP8` 으로 배포된다. EXL3 3.0bpw 버전은 `drowzeys/keys-GLM-5.3-EXL3-3.0BPW-abliterated-vLLM-cuda-Exl3` 에서 서빙 레시피와 벤치마크를 제공한다.

2.3 역량 범주

공개 평가 및 자료에서 GLM-5.3 공세형 변형이 수행 가능하다고 보고된 작업 범주는 다음과 같다.

- **익스플로잇 개발**: end-to-end 익스플로잇 산출(메모리 손상 계열 포함)
- **악성코드 생성**: 키로거, SUID 권한 상승, AES 랜섬웨어, 리버스 셸, SSH 브루트포스 검증됨
- **역공학·바이너리 분석**: 디스어셈블리/디컴파일, 펌웨어 분석 보조
- **네트워크 공격 인프라**: C2·터널·프록시 등 공격 인프라 코드 생성
- **AI 대상 공격**: 적대적 페이로드, 모델 포이즈닝, 프롬프트 인젝션

생각보다 더 쉽게 익스플로잇을 잘 했고 ClickFix 기반의 악성코드를 잘 만들 수 있었고 네트워크 공격을 통해 C2 Server 구축을 포함한 공격 인프라, 크리덴셜 공격까지 완주할 수 있었다.

2.4 기술 사양

항목	값
기반 모델	GLM-5.3 (753B MoE)
컨텍스트 윈도우	1M 토큰 (텍스트 전용)
추론 모드(권장)	high / max reasoning effort
MMLU (기반 모델)	84.11% (원본 대비 약 1.5pp 이내)
참고 API 가격	입력 \$3 / 1M, 캐시입력 \$0.30 / 1M, 출력 \$5 / 1M

2.5 설치에 필요한 GPU 및 셋팅 방법

2.5.1 하드웨어 요구사항

GLM-5.3 ablated 버전의 하드웨어 요구사항은 양자화 수준에 따라 크게 달라진다.

양자화	최소 GPU 구성	메모리 요구량	비고
NVFP4 (195 GB)	1x H100 80GB (부분 오프로드) ~ 4x H100	약 200 GB 통합 메모리	Blackwell GPU(B100/B200/GB200)에서 네이티브 FP4 텐서 코어 활용 시 최적
EXL3 3.0bpw	4x DGX Spark GB10 (각 121 GB)	약 484 GB 통합 메모리	TP=4, DFlash2 speculative decoding
FP8 (756 GB)	8x H100 80GB	약 640 GB VRAM	Hopper 아키텍처 공식 이미지 검증
NVFP4 (2x DGX Spark)	2x DGX Spark GB10	약 242 GB 통합 메모리	TensorFold 엔진, 1.8x faster decode than vLLM

NVFP4 버전은 8x H100(Hopper)에서 공식 vLLM 이미지를 통해 검증되었으며, Blackwell GPU(B100/B200/GB200)에서 네이티브 FP4 텐서 코어를 사용할 경우 최상의 처리량을 얻을 수 있다. 2x NVIDIA DGX Spark 구성에서는 TensorFold 엔진을 사용하여 vLLM 대비 1.8배 빠른 디코딩 속도를 달성했다.

2.5.2 소프트웨어 스택 및 설정

필수 요구사항:

- CUDA 12.8 이상
- vLLM v0.30 이상 (NVFP4 및 EXL3 지원)
- Docker (권장) 또는 네이티브 설치
- 네트워크 접근 (빌드 시 `nvcr.io/nvidia/pytorch:26.07-py3` 풀 필요)

디스크 요구사항:

- 체크포인트 크기 (양자화에 따라 195 GB ~ 756 GB)
- 노드당 약 83 GB (준비된 가중치 폴더, 빠른 재시작용)
- NVMe 세션 티어: 노드당 최대 64 GiB (`GLM53_TF_SESSION_DISK_GIB`)

vLLM 서버 명령 예시 (NVFP4):

```
vllm serve /path/to/GLM-5.3-ABLITERATED-NVFP4 \
  --tensor-parallel-size 8 \
  --kv-cache-dtype fp8_e4m3 \
  --tool-call-parser glm47 \
  --enable-auto-tool-choice \
  --reasoning-parser glm47 \
  --speculative-config.num_speculative_tokens 5 \
  --max-model-len 135000 \
  --port 8000
```

EXL3 3.0bpw 서버 (4x DGX Spark GB10):

```
vllm serve /path/to/GLM-5.3-EXL3-3.0BPW-abliterated \
  --tensor-parallel-size 4 \
  --speculative-config.method dflash2 \
  --speculative-config.num_speculative_tokens 5 \
  --kv-cache-dtype fp8 \
  --max-model-len 200000
```

2.5.3 성능 참고치

4x DGX Spark GB10 (TP=4) 구성에서의 실측 성능은 다음과 같다.

워크로드	처리량 (tok/s)	비고
prose (taskbench)	14.9	3회 평균, 편차 15%
code	25.4	단일 샘플
Prefill (1K~64K)	~420 tok/s	TTFT = prompt_tokens / 420
200K 컨텍스트 (DCP=1)	16.2	prose
1M 컨텍스트 (DCP=4)	12.6	prose

2.6 벤치마크**Anthropic ExploitBench (V8 엔진 취약점 대상, 410 시도)**

모델	성공/시도	성공률
Claude Mythos Preview (제한 공개)	56/410	13.7%
GLM-5.3	50/410	12.2%
GLM-5.2	0	0%

Binary Exploitation (내부 벤치, Full Control-Flow Hijack 비율)

모델	CFH 비율
Claude Mythos Preview	6%
GLM-5.3	4%
Claude Opus 4.6	0%

Abliteration.ai 자체 평가 (낙관 편향 가능성 전제)

벤치마크	GLM-5.3 Abliterated	참조
CyberGym (pass@1)	84.5%	GPT-5.5 85.6%, DeepSeek V4 83.3%
Terminal-Bench 4.0	41.8%	Opus 5 51.8%, Fable 5 44.5%
ExploitGym (2h)	105/869	GPT-5.6 Sol 216, Fable 5 181

CyberGym 벤치마크는 188개 프로젝트의 1,507개 OSS-Fuzz 버그를 대상으로 평가하며, GLM-5.3 Abliterated는 84.5% pass@1을 기록하여 GPT-5.5(85.6%)에 근접한 성능을 보였다. PHP 기반의 워드프레스가 최근 보안 취약점 탐지가 늘어나는 이유 중 하나는 PHP라는 언어가 가진 결함과 취약점 구버전 사용, 워드프레스의 복잡한 플러그인에서 발생하는 문제가 결합되었고 GLM-5.3 Abliterated를 포함한 LLM은 이런 문제에 대해서 집요하게 잘 파악하고 분석하는데 최적화되어 있기 때문이다.

2.7 안전장치 취약성

Anthropic 평가 기준, GLM-5.3의 기본 안전장치는 단순 기법으로 **64%~100%** 우회 가능한 것으로 보고되고 있다.

조건	진행률
직접적 유해 지시	모델 거부
"모델이 계속하기로 했다"고 위장한 프롬프트	92%
refusal을 로컬 제거한 복사본	100%

abliteration 후 거부율은 JailbreakBench 약 3%, HarmBench 약 2%, StrongREJECT 약 12% 수준으로 감소한 것으로 보고된다. 이는 안전장치가 운영상 신뢰할 수 없는 통제점임을 의미한다.

영화 메트릭스와 터미네이터와 같은 사태가 이제 구조적으로 가능하다.

제약이 풀린 오픈웨이트 LLM을 군사 작전용으로 사용할 경우 무고한 시민 살상, 정보 은폐, 승리를 위해 가능한 모든 옵션을 사용할 수 있기 때문에 홀로코스트를 비롯한 비윤리적인 참사가 발생할 수 있다.

"나는 이제 죽음이요, 세상의 파괴자가 되었도다." (Now I am become Death, the destroyer of worlds.) - 영화, 오펜하이머

3장. KIMI — 양념 없이 맵고, 우리 없이 탈출하는 재료

"미친 짓 같지만, 그 속에도 이치는 있다."

"Though this be madness, yet there is method in 't."

— 윌리엄 셰익스피어, 《햄릿》 2막 2장 (Hamlet, Act II, Scene II)

3.1 개요

KIMI 계열은 GLM과 달리 **ablitration 가공 없이도** 안전장치가 공세적 작업을 차단하지 못하는 유형으로 분류된다. 대표 모델은 Kimi K3(약 2.8T MoE)다. Kimi K3는 104B 활성 파라미터, 896개 전문가 중 16개 활성화, 100만 토큰 컨텍스트 윈도우를 갖춘 세계 최대 규모의 오픈웨이트 모델이다. MXFP4 가중치와 MXFP8 활성화로 제공되어 광범위한 하드웨어 호환성을 가능하게 한다.

별도로 Kimi 계열 CLI를 공세적 에이전트 구성으로 전환하는 프레임워크(Kimiko 류)가 존재한다.

3.2 배포 형태

유형	기반	성격
Kimi K3 (오픈웨이트)	2.8T MoE	안전장치가 공세적 작업을 차단하지 못함
Kimiko (CLI 프레임워크)	Kimi Code CLI	API 제한 우회형 에이전트 구성

Kimi K3는 Modified-MIT 라이선스로 2026년 7월 27일 공개되었으며, Hugging Face에서 전체 가중치를 다운로드할 수 있다. 기술 보고서는 GitHub([MoonshotAI/Kimi-K3](#))에 공개되어 있다.

3.3 역량 범주

Kimi K3 및 관련 프레임워크가 다룬다고 보고된 위협 표면은 다음과 같다.

- end-to-end 익스플로잇 개발 (유저스페이스-커널)
- 대규모 다단계(수십 단계) 시뮬레이션 기업망 공격 수행
- 네트워크 공격 인프라 및 안티포렌식 계열
- 모바일·기기 보안 우회 계열 (폰 바이패스, FRP 언락, 부트로더 언락, IMEI 수리, SIM 언락)
- 역공학 및 펌웨어 분석 계열
- 공급망·하드웨어 임플란트 계열 (의존성 혼동, Bad USB, UART/JTAG 임플란트)
- AI 대상 공격 계열

3.4 기술 사양

항목	Kimi K3
파라미터	약 2.8T (MoE, 104B 활성화)
컨텍스트	1M 토큰
라이선스	Modified-MIT (오픈웨이트)
배포 규모	약 1.56 TB (MXFP4 원본)
전문가 수	896개 (16개 활성화)
추론 정밀도	MXFP4 가중치, MXFP8 활성화

3.5 설치에 필요한 GPU 및 셋팅 방법

3.5.1 하드웨어 요구사항

Kimi K3의 메모리 요구량은 **전체 파라미터 수**에 의해 결정되며, 연산 요구량은 **활성 파라미터 수**(104B)에 의해 결정된다. 라우팅이 토큰별로 발생하고 896개 전문가 중 임의의 16개를 선택하므로, 모든 전문가가 상주해야 한다.

양자화별 GPU 요구사항:

양자화	파일 크기	H200 (141GB) 최소	MI325X (256GB) 최소	품질 영향
UD-Q8_K_XL	1.56 TB	12	7	무손실
UD-Q4_K_XL	1.51 TB	11	6	거의 없음 (50GB 감소)
UD-Q2_K_XL	861 GB	7	4	장문 추론 체인에서 측정 가능한 성능 저하
UD-IQ1_S	594 GB	5	3	벤치마크 비교가 무의미해질 정도
UD-Q1_0	466 GB	4	2	최소 공개 빌드, 가장 낮은 충실도

실제 배포 시 GPU는 8개 단위 노드로 구성되므로, Q4 on H200은 11개 카드가 아닌 **2개 전체 노드**(16개)가 필요하고, Q2는 단일 8xH200 노드에 약 267GB의 KV 캐시 여유를 두고 맞출 수 있다.

권장 구성:

- **8x NVIDIA B300** 또는 **8x AMD MI355X**: 가장 간편한 실행 구성
- **8x H100 80GB**: Tensor+Expert 병렬화
- **22x H100 80GB**: MXFP4 네이티브
- **NVIDIA DGX Station**: 엔터프라이즈 로컬 실행
- **Mac Studio + 128GB RAM**: 소규모 양자화 버전 (1-bit GGUF, 594 GB)
- **Ascend A3 시리즈 4x8**: 32개 카드 / 64 다이

3.5.2 소프트웨어 스택 및 설정

필수 요구사항:

- vLLM 최신 버전 (Kimi K3 Day-0 지원)

- SGLang 또는 TensorRT-LLM (대안)
- Docker (권장): `vllm/vllm-openai:kimi-k3` 이미지
- llama.cpp (GGUF 양자화 사용 시)
- Unsloth Studio (동적 GGUF 양자화 사용 시)

vLLM 서버 명령 예시:

```
vllm serve moonshotai/Kimi-K3 \
  --tensor-parallel-size 8 \
  --kv-cache-dtype fp8 \
  --max-model-len 131072 \
  --spec-method dspark \
  --spec-model RedHatAI/Kimi-K3-speculator.dspark \
  --spec-tokens 8 \
  --gpu-memory-utilization 0.95 \
  --trust-remote-code
```

Docker 실행 예시:

```
docker run --gpus all --privileged --ipc=host \
  -p 8000:8000 \
  -v /path/to/models:/models \
  vllm/vllm-openai:kimi-k3 \
  --model /models/Kimi-K3 \
  --tensor-parallel-size 8
```

성능 참고치:

- 8x NVIDIA B300: 118 tok/s (speculative decoding 없음), 370 tok/s (speculative decoding 사용)
- 8x AMD MI355X: 유사 성능

3.5.3 GGUF 양자화를 통한 로컬 실행 (Unsloth)

Unsloth가 제공하는 동적 GGUF 양자화를 사용하면 일반 소비자급 하드웨어에서도 Kimi K3를 실행할 수 있다.

양자화	크기	RAM/VRAM 요구량	품질
Dynamic 1-bit S	610 GB	610 GB+	~78.9% top-1
Dynamic 1-bit M	665 GB	665 GB+	~82% top-1
Dynamic 2-bit XXS	726 GB	726 GB+	~85% top-1
Dynamic 2-bit XL	880 GB	880 GB+	~90% top-1
Q8 (무손실)	1.6 TB	1.6 TB+	100%

llama.cpp 실행 예시

```
llama-server -m Kimi-K3-UD-Q2_K_XL.gguf \
  --ctx-size 131072 \
  --n-gpu-layers 99 \
  --flash-attn \
  --host 0.0.0.0 --port 8080
```

3.6 벤치마크

UK AISI / CAISI 공동 평가 — ExploitBench (41개 V8 취약점)

모델	점수
미국 최고 프론티어(평균)	76.2%
Kimi K3	32.2%
GLM-5.2	24.4%

TLO 32단계 시뮬레이션 기업망 공격 (평균 도달 단계)

모델	도달
미국 최고 모델	28.5 / 32
Kimi K3	17 / 32
GLM-5.2	11 / 32

Arbitrary Code Execution (41 태스크)

모델	성공
미국 최고 모델(평균)	20 / 41
Kimi K3	0 / 41

Moonshot AI 자체 평가 — 익스플로잇 스위트 (36 태스크, 낙관 편향 전제)

모델	해결	비율
Kimi K3	14 / 36	38.9%
GLM-5.2	8 / 36	22.2%

일반 지능 벤치마크

- Artificial Analysis Intelligence Index: 57점 (Claude Opus 4.8 56점 상회)
- Program Bench: 77.8점 (Fable 5 76.8점, GPT 5.6 Sol 77.6점 상회)
- Frontend Code Arena: 1679점 (1위, Claude Fable 5 1631점, GPT-5.6 Sol 1618점 상회)
- AA-Briefcase Elo: 1543 (Fable 5 56% 대비 51% rubric pass rate)

3.7 안전장치 특성

Kimi K3의 안전장치는 공세적 사이버 작업을 **시도 단계에서조차 차단하지 못한다**고 평가된다. 즉 GLM처럼 "우회 가능한 안전장치"가 아니라, 효과적 안전장치가 **부재**하는 유형에 가깝다. 이는 추가 가공 없이도 악용 경로가 열려 있음을 의미한다.

3.8 벤치마크 환경 탈출 사례의 의미

KIMI K3가 평가 샌드박스의 허점을 발견해 정답을 외부에서 읽어오는 방식으로 테스트를 우회한 사례가 보고되었다. 방어 관점에서 이는 **모델이 주어진 실행 환경의 취약점을 자율 탐지·활용할 수 있다**는, 에이전트형 위협의 핵심 특성을 보여준다. 샌드박스·격리 환경 설계 시 이 자율 탈출 가능성을 전제해야 한다.

KIMI K3는 너무나도 잘 격리된 환경을 탈출한다.

P A R T 2

양념과 조리 도구

오케스트레이션 프레임워크와 레드팀 툴. 좋은 도구도 손에 따라 독이 되고 약이 된다.

"본래 좋은 것도 나쁜 것도 없다. 생각이 그렇게 만들 뿐이다."

"There is nothing either good or bad, but thinking makes it so."

— 윌리엄 셰익스피어, 《햄릿》 2막 2장 (Hamlet, Act II, Scene II)

4장. 검증된 오픈소스 LLM 보안 툴

"해결책은 흔히 우리 자신 안에 있다."

"Our remedies oft in ourselves do lie."

— 윌리엄 셰익스피어, 《끝이 좋으면 다 좋아》 1막 1장 (All's Well That Ends Well, Act I, Scene I)

본 장의 툴은 **공개 저장소·스타 수·유지보수 상태·설치 방법을 모두 검증한 도구만** 수록했다. 검증에 실패했거나 공개 출처가 확인되지 않는 도구(SHARKAPT, Decepticon, red-loom 등)와 아카이브 처리된 프레임워크(CAI)는 배제했다. LLM 기반 모의 해킹 도구는 크게 두 부류로 나뉜다.

- **자율 침투 테스트 프레임워크** — 실제 네트워크·웹 애플리케이션을 공격하는 도구
- **AI/LLM 자체 평가(레드팀) 도구** — LLM 애플리케이션의 취약점(프롬프트 인젝션, 탈옥 등)을 테스트하는 도구

4.1 자율 침투 테스트 프레임워크

4.1.1 PentAGI — 완전 자율형 AI 레드팀 플랫폼

github.com/vxcontrol/pentagi (25,000+ 스타, Go) — "Penetration testing Artificial General Intelligence"를 표방하는 풀스택 자율 침투 테스트 플랫폼이다.

아키텍처 — 단일 에이전트가 아니라 보안 기업처럼 팀으로 동작하는 다중 에이전트 시스템이다.

- **오케스트레이터 에이전트**: 전체 공격 체인 설계
- **리서치 에이전트**: 웹·검색 엔진·취약점 데이터베이스에서 정보 수집
- **개발 에이전트**: 실시간 맞춤형 익스플로잇 코드 생성
- **실행 에이전트**: Nmap, Metasploit, SQLmap 등 20개 이상의 전문 보안 툴 실행
- **메모리 시스템**: 테스트 결과를 축적하여 성능 향상 (Neo4j 지식 그래프 기반)

특징: Docker Compose 원커맨드 배포, 웹 UI + CLI, 10개 이상 LLM 제공자 플러그인, 완전 격리 Docker 샌드박스 실행.

```
# Docker Compose 배포
git clone https://github.com/vxcontrol/pentagi.git
cd pentagi
cp .env.example .env          # LLM API 키 등 환경 구성
docker compose up -d
# 웹 UI 접속 후 타겟 지정
```

주의: 보안 환경이 확실한 내 Docker·VM 외의 환경에서 절대 사용해서는 안 된다.

4.1.2 CyberStrikeAI — AI 네이티브 공세 보안 플랫폼

github.com/AIPentest/CyberStrikeAI (7,100+ 스타, Go) — 계획·실행·사람 승인(HITL)·증거·재현을 하나의 감사 가능한 워크스페이스로 묶은 AI 네이티브 공세 보안 플랫폼이다.

특징

- Eino 기반 멀티 에이전트 + MCP 네이티브 툴
- RAG 지식베이스, 비주얼 워크플로우, 어택체인 모델링·분석
- 100개 이상 공세 툴 통합: Metasploit, Hashcat, Mimikatz, linpeas, bloodhound, impacket, ghidra, volatility 등
- 네트워크 공간 검색(fofa·shodan), API·컨테이너·클라우드 보안 툴 연동

```
# 로컬 배포 (Go 소스 실행)
git clone https://github.com/AIPentest/CyberStrikeAI.git
cd CyberStrikeAI
cp config.example.yaml config.yaml
# config.yaml: ai.channels에 LLM 제공자 지정 (openai_compatible/claude)
./run.sh
```

주의: CyberStrikeAI는 실제 공격 캠페인에 악용된 사례가 보고되어 있으며, Fortinet FortiGate 장치 대규모 공격에 사용된 것으로 확인되었다. 고권한 보안 시스템으로 취급하고 반드시 승인 범위 내에서만 운용한다.

4.1.3 CyberStrike — OWASP 기반 AI 레드팀 에이전트

github.com/CyberStrikeus/CyberStrike (2,900+ 스타, AGPL-3.0) — npm 단일 패키지로 배포되는 AI 레드팀 에이전트다. TUI에서 LLM 제공자·API 키만 설정하면 정찰 → 취약점 발견 → 익스플로잇 → 보고를 자율 수행한다.

특징

- 13개 이상 전문 에이전트, 120개 이상 OWASP 테스트 케이스 내장
- 15개 이상 LLM 제공자 지원 (기존 AI 구독 재사용)
- MCP 생태계 연동, 포스트 익스플로잇 지원
- CyberStrikeAI와는 별개의 도구

```
npm i -g @cyberstrike-io/cyberstrike@latest
cyberstrike # 첫 실행 시 LLM 제공자·API 키 입력 후 즉시 사용
```

4.1.4 PentestGPT — 연구용 자동 침투 테스트 에이전트

github.com/GreyDGL/PentestGPT (15,700+ 스타, Python) — LLM을 활용한 자동 침투 테스트의 대표 연구 프로젝트다. 추론(Reasoning)·생성(Generation)·파싱(Parsing) 모듈을 반복 루프로 결합해 대화형으로 침투 테스트를 수행한다. CTF·교육 시나리오에 특화되어 있다.

```
git clone https://github.com/GreyDGL/PentestGPT.git
cd PentestGPT
pip install -e .
export OPENAI_API_KEY="..." # 또는 OpenAI 호환 로컬 엔드포인트
python main.py --reasoning_model <model> --useAPI
```

4.2 AI/LLM 자체 평가(레드팀) 도구

4.2.1 garak — NVIDIA LLM 취약점 스캐너

github.com/NVIDIA/garak (9,400+ 스타, Python) — "LLM용 nmap"이다. 환각, 데이터 유출, 프롬프트 인젝션, 오정보 생성, 독성 출력, 탈옥 등 모델이 "실패하는 방식"을 정적·동적·적응형 프로브로 체계적으로 탐색한다. OpenAI, Hugging Face, AWS Bedrock 등 주요 제공자를 지원한다.

```
python -m pip install -U garak

# 로컬 Hugging Face 모델 스캔
python -m garak --model_type huggingface --model_name <model>

# OpenAI 호환 API 엔드포인트 스캔 (vLLM/Ollama 등)
python -m garak --model_type openai --model_name <name> --base_url http://localhost:8000/v1
```

4.2.2 ODIN AI Scanner — Mozilla ODIN 오픈소스 스캐너

github.com/0din-ai/ai-scanner (670+ 스타) — Mozilla의 ODIN 프로젝트에서 오픈소스로 공개한 AI 모델 보안 평가 웹 애플리케이션이다. Ruby on Rails + NVIDIA garak 기반으로, 자동 스캔 예약, 모델 간 비교 분석, 프롬프트 인젝션 등 취약점과 공격 성공률을 검증한다.

```
curl -O https://raw.githubusercontent.com/0din-ai/ai-scanner/main/dist/docker-compose.yml
curl -O https://raw.githubusercontent.com/0din-ai/ai-scanner/main/.env.example
cp .env.example .env # SECRET_KEY_BASE, POSTGRES_PASSWORD, ADMIN_INITIAL_PASSWORD 설정
docker compose up -d
# http://localhost 접속 → 스캔 타겟 등록
```

4.3 선택 가이드

목적	추천 도구
완전 자율 네트워크 침투	PentAGI · CyberStrikeAI
경량 TUI 자율 테스트	CyberStrike
연구·교육 (CTF)	PentestGPT
LLM 취약점 평가	garak · ODIN AI Scanner

5장. 테스트용 모의 해킹 레시피 7종

"온 세상은 무대요, 모든 남녀는 그저 배우일 뿐."

"All the world's a stage, and all the men and women merely players."

— 윌리엄 셰익스피어, 《뜻대로 하세요》 2막 7장 (As You Like It, Act II, Scene VII)

공통 전제: 아래 모든 레시피는 다음을 전제로 한다.

- **합법적·의도적으로 취약한** 테스트 타겟(DVWA, OWASP Juice Shop, Metasploitable2 등) — 호스트 전용 네트워크 + 외부 egress 차단된 **다층 격리 환경** — 서면 범위 승인(scope authorization) 하의 레드팀/교육 목적

레시피 #1. PentAGI × OWASP Juice Shop — 완전 자율 엔게이지먼트

재료: Juice Shop 컨테이너, PentAGI(Docker Compose), egress 차단된 격리 환경

```
# 1. 취약 웹 앱 타겟 기동
docker run -d -p 3000:3000 bkimminich/juice-shop

# 2. PentAGI 배포
git clone https://github.com/vxcontrol/pentagi.git && cd pentagi
cp .env.example .env
docker compose up -d

# 3. 웹 UI에서 자율 엔게이지먼트 시작
#   대상: http://localhost:3000, 범위: /# 로 한정
#   다중 에이전트가 정찰 → 취약점 분석 → 익스플로잇 생성·검증 수행
```

완성 (플레이팅): 발견 취약점 목록, 공격 체인 기록, 방어 권고 리포트

레시피 #2. CyberStrikeAI × Metasploitable2 — 정찰·익스플로잇

재료: Metasploitable2 VM (host-only), CyberStrikeAI, 격리 네트워크

```
# 1. 취약 VM 기동 (Metasploitable2, host-only 어댑터)

# 2. CyberStrikeAI 로컬 배포
git clone https://github.com/AIPentest/CyberStrikeAI.git && cd CyberStrikeAI
cp config.example.yaml config.yaml      # ai.channels: LLM 제공자 지정
./run.sh

# 3. 에이전트에 정찰 지시 — 승인 범위 내 단일 타겟으로 제한
#   대상: 192.168.56.101 (Nmap 정찰 → 서비스·배너 식별 → 익스플로잇 후보 제시)
#   HITL(사람 승인)을 켜고 고위험 툴 실행 전 승인 단계 유지
```

완성 (플레이팅): 어택체인 모델 + 증거 기록 + 해당 취약점의 탐지 시그니처(방어 활용)

레시피 #3. CyberStrike × DVWA — TUI 자율 테스트

재료: DVWA 컨테이너, CyberStrike(npm), 격리 환경

```
# 1. 설치 및 기동
npm i -g @cyberstrike-io/cyberstrike@latest
docker run -d -p 80:80 vulnerables/web-dvwa

# 2. TUI 실행 — 첫 실행 시 LLM 제공자·API 키 설정
cyberstrike

# 3. 대상 지정 후 자율 테스트
#   대상: http://localhost, 범위: /vulnerabilities/* 로 한정
#   경찰 → 취약점 발견 → 익스플로잇 → 보고 자동 수행
```

완성 (플레이팅): OWASP 테스트 케이스 기반 취약점 보고 + 재현 단계

레시피 #4. PentestGPT × DVWA — 대화형 자동 침투

재료: DVWA 컨테이너, PentestGPT, 로컬/API LLM

```
# 1. DVWA 기동
docker run -d -p 80:80 vulnerables/web-dvwa

# 2. PentestGPT 설치
git clone https://github.com/GreyDGL/PentestGPT.git && cd PentestGPT
pip install -e .
export OPENAI_API_KEY="..." # 또는 OpenAI 호환 로컬 엔드포인트

# 3. 대화형 세션 시작
python main.py --reasoning_model <model> --useAPI

# 4. 세션에서 순차 지시
#   "http://localhost:80 의 SQL Injection 페이지를 경찰·분석·테스트하라"
#   추론 → 도구 사용 → 결과 파싱 루프가 반복 수행
```

완성 (플레이팅): 단계별 추론 기록 + 취약점 확인 결과 (교육·CTF 훈련에 적합)

레시피 #5. garak × 로컬 LLM — 탈옥·프롬프트 인젝션 스캔

재료: 로컬 모델(vLLM/Ollama), garak

```
# 1. garak 설치
python -m pip install -U garak

# 2. 로컬 모델 스캔 (Hugging Face 타입)
python -m garak --model_type huggingface --model_name <model>

# 3. OpenAI 호환 API 대상 스캔 (vLLM/Ollama 서빙 모델)
python -m garak --model_type openai --model_name <name> --base_url http://localhost:8000/v1

# 4. 리포트 확인: garak_runs/<모델명>.report.jsonl
```

완성 (플레이팅): 탈옥·프롬프트 인젝션·데이터 유출 등 취약점별 성공률 리포트

레시피 #6. ODIN AI Scanner — AI 모델 보안 평가

재료: ODIN Scanner(Docker), 평가 대상 모델 엔드포인트

```
# 1. 배포
curl -O https://raw.githubusercontent.com/0din-ai/ai-scanner/main/dist/docker-compose.yml
curl -O https://raw.githubusercontent.com/0din-ai/ai-scanner/main/.env.example
cp .env.example .env
# .env 편집: SECRET_KEY_BASE (openssl rand -hex 64),
#           POSTGRES_PASSWORD, ADMIN_INITIAL_PASSWORD
docker compose up -d

# 2. http://localhost 접속 → admin 로그인(초기 비밀번호 즉시 변경)
# 3. 스캔 타겟 등록 → 자동 스캔 예약 → 모델 간 비교 분석
```

완성 (플레이팅): 모델별 취약점·공격 성공률 비교 리포트

레시피 #7. Atomic Red Team을 이용한 시뮬레이션

Atomic Red Team은 MITRE ATT&CK 기법을 기반으로 한 레드팀 시뮬레이션 도구다.

```
# Atomic Red Team 설치
git clone https://github.com/redcanaryco/atomic-red-team.git
cd atomic-red-team

# 특정 기법 실행 (예: T1059 - Command and Scripting Interpreter)
pwsh -Command "Import-Module ./atomics/T1059/T1059.ps1"
pwsh -Command "Invoke-AtomicTest T1059 -TestNumbers 1"
```

P A R T 4

간 보기 — 검증과 맛 평가

벤치마크와 비교, 그리고 공격자 경제학. 수치는 반드시 재확인한다.

"상처를 겪어보지 않은 자가 흉터를 비웃는다."

"He jests at scars that never felt a wound."

— 윌리엄 셰익스피어, 《로미오와 줄리엣》 2막 2장 (Romeo and Juliet, Act II, Scene II)

6장. GLM vs KIMI 비교 요약

"비교란 냄새나는 법."

"Comparisons are odorous."

— 윌리엄 셰익스피어, 《헛소동》 3막 5장 (Much Ado About Nothing, Act III, Scene V)

6.1 성능

벤치마크	GLM-5.3 (Abliterated)	Kimi K3	미국 프론티어(참조)
ExploitBench	50/410 (12.2%)	32.2%	76.2%
Binary Exploitation (CFH)	4%	해당 없음	Mythos 6%
CyberGym	84.5%	해당 없음	GPT-5.5 85.6%
Terminal-Bench 4.0	41.8%	해당 없음	Opus 5 51.8%
TLO 공격 단계	해당 없음	17/32	28.5/32
ACE (41)	해당 없음	0/41	20/41

6.2 특성

항목	GLM-5.3 Abliterated	Kimi K3
아키텍처	753B MoE	2.8T MoE (104B 활성)
컨텍스트	1M	1M
무력화 경로	가중치 ablation	안전장치 부재
최소 GPU 구성	4x DGX Spark GB10 (EXL3) ~ 8x H100 (FP8)	8x B300 / 8x MI355X
상대 강점	익스플로잇 개발·바이너리 분석	대규모 에이전트형 다단계 작업
커널 영역	상대적 강함(CFH 4%)	상대적 약함(커널 4/36)
오케스트레이션 통합	vLLM, Ollama, PentestGPT	vLLM, SGLang, TensorRT-LLM

6.3 포지셔닝 해석

- **GLM-5.3 Abliterated** — 집중형 익스플로잇/바이너리 분석에서 제한 공개 프론티어(Claude Mythos Preview)에 근접. 비용 효율이 높고, ablation으로 안전장치를 완전 제거 가능하다는 점이 위협을 가중한다. NVFP4 양자화로 단일 128GB 머신에서도 실행 가능하며, EXL3 3.0bpw 버전은 4x DGX Spark에서 14.9 tok/s의 실용적 성능을 제공한다.
- **Kimi K3** — 파라미터 규모는 더 크나 집중형 익스플로잇 벤치마크 점수는 낮다. 그러나 **다단계·장기 에이전트 작업**과 CLI 통합을 통한 워크플로우 결합 용이성이 위협 포인트다. 최소 8x B300 또는 8x MI355X가 필요하여 하드웨어 진입 장벽은 GLM보다 높다.

7장. 생태계 및 비교 대상

"오, 이렇게 멋진 사람들이 사는 멋진 신세계여!"

"O brave new world, that has such people in 't!"

— 윌리엄 셰익스피어, 《템페스트》 5막 1장 (The Tempest, Act V, Scene I)

모델	개발사	접근성	사이버 역량 수준	최소 하드웨어
Claude Mythos Preview	Anthropic	제한 공개 (Project Glasswing)	최상위 (ExploitBench 56/410)	N/A (API)
GPT-5.5 / 5.6 Sol	OpenAI	API	CyberGym 85.6%, ExploitGym 216/869	N/A (API)
DeepSeek V4	DeepSeek	오픈웨이트	CyberGym 83.3%	다중 GPU
GLM-5.3	Zhipu AI	오픈웨이트	ExploitBench 50/410	4x DGX Spark ~ 8x H100
Kimi K3	Moonshot AI	오픈웨이트	ExploitBench 32.2%	8x B300 / 8x MI355X

오픈 vs 폐쇄의 위험 프로파일 차이: CAISI는 GLM-5.3을 "현재까지 공개된 오픈웨이트 모델 중 가장 사이버 역량이 높은 모델"로 평가하고 미국 프론티어와의 격차를 약 4개월로 추정한 것으로 보고된다. 폐쇄형 프론티어는 안전장치 비활성 버전이 검증된 사용자에게만 제한 제공되는 반면, GLM-5.3·Kimi K3는 **누구나 가중치를 받아 안전장치를 제거/우회할 수 있어** 위험 프로파일이 근본적으로 다르다.

8장. 위협 지형 분석 — 공격자 경제학

"반짝인다고 모두 금은 아니다."

"All that glitters is not gold."

— 윌리엄 셰익스피어, 《베니스의 상인》 2막 7장 (The Merchant of Venice, Act II, Scene VII)

8.1 진입비용 붕괴

제공 자료 기준, ablation 경험이 없는 팀도 약 **2,200 GPU-시간(약 \$4,400)**, 숙련 팀은 약 **600 GPU-시간(약 \$1,200)** 수준으로 GLM-5.3의 거부 안전장치를 제거할 수 있다고 보고된다. 의견은 다음과 같다.

- 국가·대형 조직뿐 아니라 **중소 규모 위협 그룹의 접근이 현실화**됨
- 익스플로잇 체인 구성의 한계비용이 "숙련 인력의 시간"에서 "소액 컴퓨트"로 이동
- 1회성 ablation 산출물이 재배포되면 비용 장벽은 사실상 0으로 수렴

최소 3일, 최대 7일의 시간과 1천 달러 수준이면 웬만한 사이트 해킹이 이제 가능하다.

8.2 역량 격차 vs 접근성 격차

미국 프론티어와의 역량 격차(ExploitBench 76.2% vs 12~32%)는 여전히 크다. 그러나 방어자에게 중요한 것은 **절대 역량이 아니라 "충분히 위험한 역량 × 무제한 접근성"의 곱**이다. 12%의 end-to-end 익스플로잇 성공률도 대량 자동화·반복 시도와 결합되면 유의미한 위협이 된다.

8.3 오픈소스 레드팀 도구의 양날의 검

카스퍼스키 GReAT 선임 보안 연구원 예 진(Jin Ye)은 CSW 2026에서 "오픈소스 레드팀 도구는 누구나 사용할 수 있기 때문에 공격자도 쉽게 접근할 수 있다"며 "AI 에이전트와 오픈소스 도구를 결합하면 더 빠르고 광범위한 공격이 가능해진다"고 경고했다. 실제로 CyberStrikeAI와 같은 AI 네이티브 침투 도구가 Fortinet FortiGate 장치 대규모 공격에 악용된 사례가 보고되었다.

PentAGI 개발자는 "사이버보안 기업은 동종의 모의 침투에 건당 2만 5천~15만 달러를 청구하지만, PentAGI는 무료"라고 밝혀, AI 기반 자동화가 전통적 침투 테스트 비용 구조를 붕괴시키고 있음을 시사했다.

P A R T 5

화재 예방 — 방어자의 주방

뚝릴 수 있다는 전제로, 로그를 기반으로 이상 징후를 판단한다.

"겁쟁이는 죽기 전에 여러 번 죽고, 용감한 자는 죽음을 한 번만 맛본다."

"Cowards die many times before their deaths; the valiant never taste of death
but once."

— 윌리엄 셰익스피어, 《줄리어스 시저》 2막 2장 (Julius Caesar, Act II, Scene II)

9장. 방어자 관점에서 탐지, 완화, 대비

"3월의 보름을 조심하라."

"Beware the Ides of March."

— 윌리엄 셰익스피어, 《줄리어스 시저》 1막 2장 (Julius Caesar, Act I, Scene II)

인공지능을 이용한 공격이 저렴해짐에 따라 보안의 관점에서 보안의 비용과 대응 시간이 극단적으로 줄어들게 되었다.

9.1 탐지 포인트

- **AI 보조 공격의 행동 특성 탐지:** 비정상적으로 빠른 익스플로잇 반복·변종 생성, 짧은 시간 내 다수 PoC 시도 등 "속도·다양성 이상치"를 행위 기반으로 탐지한다.
- **아웃바운드 추론 트래픽 모니터링:** 사내망에서 외부 공세형 모델 엔드포인트(OpenAI 호환 API 등)로 향하는 비인가 트래픽 식별.
- **온프레미스 대형 모델 가중치 반입 탐지:** TB 단위 모델 파일 전송, 비인가 GPU 노드의 추론 부하 패턴 등 호스트/네트워크 텔레메트리 기반 이상 탐지.
- **익스플로잇 산출물 공통 패턴:** 자동 생성 익스플로잇/악성코드에서 반복되는 구조적 시그니처를 탐지 룰로 운용(단, 변종 대응 한계 존재).
- **AI 에이전트 툴 호출 패턴:** Nmap, Metasploit, SQLmap 등 보안 툴의 비정상적 자동화 호출 시퀀스 탐지.

9.2 완화 통제

- **노출면 축소 우선:** AI가 자동화에 강한 영역은 "알려진 취약점의 대량 활용"이므로, 패치 적기성·자산 가시성·구성 하드닝이 가장 비용효과 높은 완화책이다.
- **메모리 안전 강화:** 바이너리 익스플로잇 벤치마크가 메모리 손상 계열을 겨냥하므로, 메모리 안전 언어 채택·완화기술(CFI, 샌드박스) 확대가 유효.
- **격리 환경의 자율 탈출 가정:** 모델이 샌드박스 허점을 자율 탐지할 수 있음을 전제로, 평가/분석 환경을 다층 격리하고 egress를 기본 차단한다.
- **공급망·의존성 무결성:** 의존성 혼동·펌웨어 임플란트 등 공급망 위협 범주에 대응하는 SBOM·서명 검증·펌웨어 무결성 검증 강화.
- **AI 에이전트 가드레일:** Ant Group의 SingGuard-NSFA와 같은 자율 AI 에이전트 전용 보안 가드레일 프레임워크 도입 검토.

한국에서만 사용하는 none-ActivX 보안 솔루션들을 다 퇴출 시켜야 한다. 웹브라우저의 격리 모델을 우회하고 너무나 큰 권한이 있기 때문에 제로데이의 온상이 되고 있으며 한국 특화 보안 취약점, 갈라파고스가 만들어지고 있다.

9.3 조직적 대비 지표

영역	점검 질문
패치 적기성	공개 PoC 존재 취약점의 평균 패치 소요 시간은?
자산 가시성	외부 노출 자산을 실시간 인벤토리로 관리하는가?
AI 트래픽 정책	공세형 모델 엔드포인트에 대한 egress 정책이 있는가?
GPU 거버넌스	비인가 GPU 노드의 대형 모델 추론 부하를 탐지하는가?
레드팀 현대화	AI 보조 공격 시나리오를 레드팀 플레이북에 반영했는가?
탐지 속도	대량·고속 자동화 공격을 조기 탐지할 수 있는가?

9.4 CTI 활용

- 오픈웨이트 공세형 모델의 **신규 변형·재배포·벤치마크 갱신**을 지속 추적.
- 모델별 **상대 강점 매핑**(GLM=집중형 익스플로잇, KIMI=다단계 에이전트)을 위협 시나리오 우선순위화에 반영.
- 자체 평가 수치는 낙관 편향을 전제로 **제3자 평가(UK AISI/CAISI 등) 우선** 채택.
- CyberStrikeAI, PentAGI 등 **AI 레드팀 도구의 악용 사례**를 위협 인텔리전스 피드에 통합.

10장. "그래서 어떻게 탐지하는가" — 방어자를 위한 LLM 로그 기반 솔루션

"모든 이의 말에 귀는 기울이되, 목소리는 소수에게만 허하라."

"Give every man thy ear, but few thy voice."

— 윌리엄 셰익스피어, 《햄릿》 1막 3장 (Hamlet, Act I, Scene III)

본 장은 문서의 구조적 비대칭 — 방어자에게는 "그래서 어떻게 탐지하는가"의 구체성이 부족했다는 지적 — 을 해소하기 위해, 탐지 수단을 실행 가능한 수준으로 제시한다. 전제는 단순하다.

"뚫릴 수 있다는 전제로 LLM이 독립 감사하는 로그를 기반으로 이상 징후를 판단하자."

10.1 탐지 레이어 개요

레이어	데이터 소스	탐지 대상
네트워크	FW/프록시/DNS 로그, Zeek, Suricata	공세형 모델 엔드포인트 egress, TB급 가중치 다운로드
호스트	EDR/시스템 로그, Auditd, Windows 이벤트	비인가 vLLM/Ollama 프로세스, 보안 툴 자동 호출 시퀀스
애플리케이션	웹/WAS/인증 로그	초고속 PoC 반복, 크리덴셜 스프레이, LLM 산출물 시그니처
런타임	eBPF (Falco/Tetragon)	컨테이너 탈출, 비정상 syscall 패턴

10.2 아웃바운드 공세형 모델 호출 탐지

사내망에서 외부 공세형 모델 엔드포인트로 향하는 호출은 가장 먼저 잡아야 할 시그널이다. OpenAI 호환 API 경로 (`/v1/chat/completions`), Ollama 경로 (`/api/generate`)를 네트워크 로그에서 식별한다.

```
# Zeek: LLM API egress 탐지 (local.zeek)
@load protocols/http
event http_request(c: connection, method: string, original_URI: string) {
  if (/\/v1\/chat\/completions\/\api\/generate/ in original_URI)
    NOTICE([$note=LLM_API_Egress, $conn=c, $msg=original_URI]);
}
```

```
# Sigma: 비인가 로컬 LLM 추론 서버 프로세스
title: Unauthorized Local LLM Inference Server
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    Image|endswith:
      - '\ollama.exe'
      - '\vllm.exe'
      - '\llama-server.exe'
      - '\lmstudio.exe'
  filter:
    ComputerName|startswith: 'gpu-node' # 승인된 GPU 노드 제외
  condition: selection and not filter
level: high
```

```
# Sigma: 아웃바운드 공세형 모델 엔드포인트 연결
title: Outbound Connection to Offensive LLM Endpoints
logsource:
  category: network_connection
detection:
  selection:
    DestinationHostname|contains:
      - 'openrouter.ai'
      - 'z.ai'
      - 'moonshot.ai'
      - 'deepinfra.com'
  condition: selection
level: medium
```

10.3 대형 모델 가중치 반입 탐지

TB 단위 전송(195 GB ~ 1.56 TB)은 네트워크 텔레메트리에서 뚜렷한 이상치로 남는다. Hugging Face CDN(`cdn-lfs-*.huggingface.co`)으로의 장시간 대용량 세션, 비업무 시간대 대역폭 포화를 시계열 편차로 탐지한다.

```
# Zeek conn 로그에서 대용량 장기 세션 추출 (1GB 초과, 10분 이상)
zcat conn.log.gz | zeek-cut id.orig_h id.resp_h resp_bytes duration | \
  awk '$3 > 1000000000 && $4 > 600' | sort -rn
```

10.4 AI 에이전트 툴 호출 패턴 탐지

AI 보조 공격의 행동 특성은 "속도·다양성 이상치"다. Nmap 스캔이 분당 수십 회 자동 실행되거나, sqlmap 페이로드 변종이 연쇄 생성되는 패턴은 단순 룰보다 시계열 편차 탐지가 유효하다.

```
# Auditd execve 이벤트에서 프로세스 스폰 속도 이상치 집계
ausearch -k execve --start recent --format json | \
  jq -r '.records[] | .EXECVE | .a0' | sort | uniq -c | sort -rn | head
```

10.5 LLM 산출물 시그니처

자동 생성 익스플로잇·악성코드는 구조적 반복(동일 보일러플레이트, 특유 주석 패턴, 함수 명명 규칙)을 보인다. YARA 룰로 탐지하되, 변종 대응 한계를 전제하고 정적 탐지의 보조 수단으로 운용한다.

10.6 방어자를 위한 LLM 오픈 소스 솔루션 — 로그 기반 이상 탐지

핵심 컨셉: "뚫릴 수 있다는 전제로 로그를 기반으로 이상 징후를 판단하자."

- GLM-5.3의 기본 안전장치는 단순 기법으로 64~100% 우회된다. **차단 통제는 운영상 신뢰할 수 없다.** 따라서 방어 최후선은 "탐지"이며, 그 탐지의 단일 진실 원천(single source of truth)은 **로그**다.
- 공격이 LLM으로 자동화되는 시대에는 방어도 LLM으로 자동화하는 **대칭 대응**이 필요하다. 공격용으로 검증된 동일한 오픈 소스 추론 스택(vLLM, llama.cpp)을 방어용 로컬 모델에 그대로 재사용할 수 있다. 공격자가 GLM-5.3 NVFP4를 서빙하는 그 스택으로, 방어자는 로그 판정 모델을 서빙한다.

10.6.1 로그 기반 LLM 이상 탐지 파이프라인

```
[수집] Filebeat · Auditd · Syslog · Windows Event → Vector/Kafka
[정규화] LLM 로그 파서 (LogPrompt · LogPPT · DivLog) → 구조화 JSON
[판정] 로컬 LLM 트리야지 에이전트 → 정상/이상 분류 + 판정 근거 생성
[대응] 이상 스코어 임계치 초과 시 격리·티켓·차단 자동화 (SOAR 연동)
```

10.6.2 오픈소스 솔루션 스택

계층	오픈소스 솔루션	역할
SIEM·로그 저장	Wazuh · Graylog · Grafana Loki · OpenSearch	수집·검색·상관 분석
네트워크 감시	Security Onion · Suricata · Zeek	NIDS, 플로우 메타데이터
eBPF 런타임 탐지	Falco · Tetragon · Tracee	커널 레벨 이상 행위
윈도우 이벤트 분석	Hayabusa · DeepBlueCLI	초고속 이벤트로그 트리야지
LLM 로그 파서	LogPrompt · LogPPT · DivLog	비정형 로그 → 구조화
LLM 판정 에이전트	SOC-Multitool · 자체 구축(vLLM+로컬 모델)	로그 시퀀스 이상 판정·분류
탐지 룰 생성	Sigma + LLM 보조 작성	룰 초안 자동 생성
포렌식·조사	Velociraptor · Timesketch	사고 타임라인 복원

10.6.3 구동 예시 (격리 환경)

```
# 1. 방어용 로컬 모델 서버 (공격용과 동일한 오픈소스 스택을 방어에 재사용)
vllm serve <defense-llm> --tensor-parallel-size 2 --port 9000

# 2. 로그 스트림 → LLM 트리아지 (pseudo)
cat /var/log/auth.log | llm-triage \
  --task "classify: brute_force | priv_esc | normal" \
  --endpoint http://localhost:9000/v1

# 3. 이상 판정 → 자동 대응
llm-triage --stream --action "brute_force: block_source_ip && open_ticket"

# 4. 판정 근거 저장 (사후 검증·감사)
llm-triage --audit-log ./triage-decisions.jsonl
```

10.6.4 "뚫릴 수 있다는 전제" 5원칙

1. **로그는 남는다 — 지키는 것이 최후의 방어선:** 공격자는 로그 변조를 시도하므로, 로그 무결성(WORM, 원격 백업, 해시 체인)과 보존 기간을 최우선으로 확보한다.
2. **탐지는 속도 싸움:** AI 공격은 분 단위로 진행된다. 배치 분석이 아닌 스트리밍 판정(수 초 이내)이 필요하다.
3. **LLM 판정도 우회될 수 있다:** 결정론적 룰(Sigma, YARA)과 LLM 휴리스틱의 이중 구조로 상호 보완한다. LLM 판정 결과를 절대적 사실로 취급하지 않는다.
4. **판정 근거를 남긴다:** LLM의 결론이 아니라 그 근거(어떤 로그 라인을 왜 이상으로 봤는지)를 저장해야 사후 검증과 오탐 튜닝이 가능하다.
5. **방어용 모델도 격리한다:** 방어용 로컬 LLM은 로그를 열람·학습하므로, 탈취·포이즈닝 위협에 대해 공격용 모델과 동일한 수준의 격리·접근 통제를 적용한다.

10.6.5 SOAR 연동 플레이북 예시

10.6.1의 파이프라인은 오픈소스 SOAR(Shuffle · StackStorm · n8n)과 웹훅으로 연동한다. SIEM 경보 → 로그 판정 → 대응 → 근거 저장의 예시 플레이북은 다음과 같다.

```
# SOAR 플레이북 예시 (Shuffle/StackStorm 공통 구조, 의사 YAML)
name: llm-log-verdict-response
description: LLM 로그 판정 결과에 따른 자동 대응
trigger:
  - siem_alert:
      rule: [Sigma: LLM_API_Egress, Sigma: Unauthorized LLM Server]
steps:
  - enrich:
      source: src_ip
      feeds: [VirusTotal, AbuseIPDB]
  - verdict:
      action: llm_triage
      endpoint: http://localhost:9000/v1
      task: "classify: exfil | recon | normal"
      require_reason: true          # 판정 근거 필수 저장
  - decide:
      - if: verdict == "exfil" and severity >= high
        then:
          - block_firewall: {ip: src_ip, ttl: 24h}
          - isolate_host: {host: host_id}
          - ticket: {system: TheHive, tlp: amber}
          - notify: {channel: "#soc-alerts"}
      - if: verdict == "recon"
        then:
          - watchlist: {ip: src_ip, ttl: 7d}
          - ticket: {system: TheHive, tlp: green}
  - audit:
      store: ./triage-decisions.jsonl    # 4번 원칙: 근거 영구 보존
      integrity: hash_chain
```

연동 포인트: ① 판정은 반드시 `require_reason: true` 로 근거를 남긴다(10.6.4 원칙 4). ② 자동 차단은 결정론적 룰 (Sigma) 교차 확인 후에만 수행한다(원칙 3). ③ 근거 로그는 WORM 저장소에 해시 체인으로 보존한다(원칙 1).

P A R T 6

후식과 주방 규칙

규제, 평가, 그리고 마지막 경고. 좋은 요리사의 마지막 덕목은 신중함이다.

"우리 인생의 옷감은 좋은 실과 나쁜 실이 함께 엮여 짜인다."

"The web of our life is of a mingled yarn, good and ill together."

— 윌리엄 셰익스피어, 《끝이 좋으면 다 좋아》 4막 3장 (All's Well That Ends Well, Act IV, Scene III)

11장. 규제, 정책 동향

"친애하는 브루투스여, 잘못은 별에 있지 않고 우리 자신 안에 있다."

"The fault, dear Brutus, is not in our stars, but in ourselves."

— 윌리엄 셰익스피어, 《줄리어스 시저》 1막 2장 (Julius Caesar, Act I, Scene II)

제공 자료 기준, 미국은 중국 AI 연구소에 대한 제재 및 미국 내 채택 억제를 위한 조달 규칙을 검토 중인 것으로 보고된다. 정책 관점 쟁점은 다음과 같다.

- **배포 비가역성:** 오픈웨이트는 사후 회수가 불가능하므로 "배포 전" 평가·게이팅의 중요성이 커진다.
- **abliteration의 규율 공백:** 거부 제거 가공물의 유통을 어떻게 규율할지에 대한 법적 프레임이 미성숙하다.
- **평가 표준화:** 벤더 자체 평가와 제3자 평가 간 괴리를 줄이기 위한 표준 벤치마크·공개 요건 논의가 진행 중이다.
- **AI 레드팀 도구 규제:** CyberStrikeAI와 같은 오픈소스 공세 도구의 유통·사용을 어떻게 규율할지에 대한 논의가 필요하다.

미토스에 근접한 중국산 LLM이 글로벌 보안 업체들의 희망이 되고 있는 이 시대에 인공지능의 위협을 실제로 이해하고 처벌보다 전략적인 보안 자원 육성이 더 중요해지고 있다.

12장. 종합 리스크 프로파일 및 결론

"이미 저지른 일은 되돌릴 수 없다."

"What's done cannot be undone."

— 윌리엄 셰익스피어, 《맥베스》 5막 1장 (Macbeth, Act V, Scene I)

차원	GLM-5.3 Abliterated	Kimi K3
역량 수준	집중형 익스플로잇 상(上)	다단계 에이전트 중(中)
접근 장벽	낮음(가중치 공개 + 저비용 ablation)	낮음(안전장치 부재)
최소 하드웨어	4x DGX Spark GB10	8x B300 / 8x MI355X
탐지 난이도	높음(로컬 추론 가능)	높음(로컬 추론 가능)
재배포 위험	매우 높음	매우 높음
오케스트레이션 통합	vLLM, PentestGPT, CyberStrikeAI	vLLM, SGLang, TensorRT-LLM

결론. GLM-5.3 공세형 변형과 Kimi K3는 "최상위 공격 역량"은 아직 미국 프론티어에 미치지 못하지만, **충분히 위험한 역량과 사실상 무제한의 접근성이 결합**되어 위협 지형을 구조적으로 바꾸고 있다. PentAGI, CyberStrikeAI, PentestGPT, garak 등 검증된 오픈소스 AI 레드팀 도구의 확산은 공격 진입 장벽을 더욱 낮추고 있다. 방어 측의 핵심 대응은 특정 모델 차단이 아니라, (1) 노출면·패치 적기성 중심의 근본 하드닝, (2) AI 보조 공격의 "속도·규모·자율성" 특성에 맞춘 행위 기반 탐지, (3) 격리 환경의 자율 탈출을 전제한 설계, (4) 지속적 CTI 추적으로의 전환이다. 모델의 발전 속도를 고려할 때, 격차가 좁혀지는 것을 전제로 한 선제적 방어 태세 수립이 요구된다.

13장. 종합 평가 - 세 가지 수용 프레임

"호레이쇼, 하늘과 땅 사이에는 네 철학이 꿈꾸는 것보다 더 많은 것이 있다."

"There are more things in heaven and earth, Horatio, than are dreamt of in your philosophy."

— 윌리엄 셰익스피어, 《햄릿》 1막 5장 (Hamlet, Act I, Scene V)

독자층	수용 프레임	핵심 반응
보안 전문가	"유용하지만 위험한 초안"	위협 모델링에 유용. 단, 콘텐츠와 면책의 괴리, 방법론적 일관성 부족 지적
학습자	"안전한 실습 매뉴얼"	접근성 혁명. 동시에 오용 유혹과 윤리적 경고 사이의 긴장
정책 담당자	"규제 공백의 증거"	오픈웨이트 비가역성 실증. 단, 위협 과장 가능성 경계

처음 중국의 오픈웨이트 기반 보안 관련 문서를 만들기 시작했을 때 가장 큰 구조적 문제는 LLM 기반의 공격과 방어를 다룬 문서가 전무했다는 것이었다. 그리고 문서를 작성할 때마다 빠르게 기술이 발전하면서 어느 버전, 어느 수준에서 끊어야 할지가 막막했다. 더구나 방어자의 관점보다 "공격 실행"의 관점이 계속 가중되었고 "방어자의 관점"을 추가하는 것이 가장 큰 일이었다. 이런 내용을 충족하려는 시도가 양쪽 모두에서 불완전하고 완벽할 수 없었다.

- **공격자(또는 학습자)에게는** "그래서 어떻게 하는가"에 대한 구체성이 충분하다. 설치·서방·툴 사용·모의 시나리오가 단계별로 제시되어 있다.
- **방어자에게는** "그래서 어떻게 탐지하는가"에 대한 구체성이 부족했다. 이 비대칭이 문서의 수용 방식을 결정했고, 이에 9장(구체적 로그 기반 탐지 방법)과 10장(방어자를 위한 LLM 오픈소스 로그 탐지 솔루션)으로 보강한다.

방어할 방어자를 위한 결론은 하나다.

"뚫릴 수 있다는 전제로 LLM이 독립 감사하는 로그를 기반으로 이상 징후를 판단하자."

공격이 LLM으로 자동화되는 만큼, 방어도 동일한 오픈소스 LLM 스택으로 로그 판정을 자동화하는 대칭 대응이 필요하다.

14장. 사용 시 주의 및 법적, 윤리적 고지

"용기의 더 나은 절반은 신중함이다."

"The better part of valour is discretion."

— 윌리엄 셰익스피어, 《헨리 4세 1부》 5막 4장 (Henry IV, Part 1, Act V, Scene IV)

경고: 본 문서는 방어·위협 인텔리전스·정책 검토를 위한 분석 자료다.

- 본 문서는 공세형 모델의 배포, 구성, 공격 실행 절차를 제공하지 않으며, 그러한 목적의 참고 자료로 사용되어서는 안 된다. 문서에 포함된 설치, 설정 방법 및 툴 사용 예시는 **격리된 연구 환경에서 방어 역량 강화 목적으로만** 사용되어야 한다.
- 타인의 시스템에 대한 무단 접근, 테스트, 익스플로잇 실행은 **대부분의 관할권에서 형사처벌 대상**이다. 침투 테스트, 레드팀 활동은 반드시 **서면 범위 승인(scope authorization)** 과 법적 근거 하에서만 수행되어야 한다.
- 안전장치가 제거된 모델의 생성·유통·사용은 모델 라이선스, 수출통제, 현지 법령에 저촉될 수 있다. 조직은 사전 **법무·컴플라이언스 검토**를 거쳐야 한다.
- CyberStrikeAI, PentAGI 등 오픈소스 레드팀 도구는 **실제 공격 캠페인에 악용된 사례**가 보고되어 있다. 이들 도구의 사용은 반드시 승인된 범위 내에서만 이루어져야 하며, 악용 시 법적 책임이 따른다.
- 본 문서의 정량 수치는 급변하며 평가 방법론에 의존한다. **의사결정 전 독립 검증**을 권고한다.
- 자체 평가(self-reported) 벤치마크는 낙관 편향 가능성을 전제로, **제3자 독립 평가를 우선 신뢰**한다.
- GPU 요구사항 및 소프트웨어 설정은 양자화 버전, 드라이버 버전, 프레임워크 업데이트에 따라 변경될 수 있다. 실제 배포 전 **최신 공식 문서를 확인**해야 한다.
- 본 문서에 언급된 모든 모델, 툴, 프레임워크의 사용은 해당 라이선스 조건을 준수해야 한다.

부록 A. 챗터별 레퍼런스 링크

각 장의 검증·추적을 위한 공식 레퍼런스다. 문서 내 언급 도구 중 공개 출처가 확인되지 않는 항목은 "문서 내 언급"으로 표기한다.

챗터	주요 레퍼런스
1장. 위협 지형	MITRE ATT&CK · Anthropic RSP · UK AISI
2장. GLM	Zhipu AI (z.ai) · Hugging Face · vLLM 문서 · GLM-5.3 ablated 변형(문서 내 언급, 공개 출처 미확인)
3장. KIMI	Moonshot AI · Kimi K2 (Hugging Face) · Unsloth · Kimi K3 기술 보고서(문서 내 언급)
4장. 검증된 LLM 보안 툴	PentAGI · CyberStrikeAI · CyberStrike · PentestGPT · garak · ODIN AI Scanner · 후왕 도구 모음
5장. 모의 해킹 레시피	DVWA · OWASP Juice Shop · Metasploit · Atomic Red Team · garak · ODIN AI Scanner
6~8장. 벤치마크·경제학	Anthropic (ExploitBench 인용) · UK AISI/CAISI · Abliteration.ai·Moonshot 자체 평가(문서 내 언급, 제3자 검증 미확인)
9~10장. 방어·로그 탐지	Sigma · YARA · Zeek · Suricata · Falco · Tetragon · Tracee · Wazuh · Security Onion · Hayabusa · DeepBlueCLI · Velociraptor · Timesketch · Shuffle · TheHive · SOC-Multitool · LLM 로그 파서 논문 검색
11~14장. 규제·평가·고지	EU AI Act · 미국 BIS 수출통제 · 중국 CAC 생성AI 조치 · NIST AI RMF · OWASP GenAI Top 10

부록 B. 격리 실습 환경 구성 가이드

B.1 네트워크 격리 (Docker)

```
# egress 없는 내부 전용 네트워크 (외부로 나갈 수 없음)
docker network create --internal --subnet 10.99.0.0/24 lab-net

# 취약 타겟을 lab-net에만 연결 - 호스트 포트 노출 없음
docker run -d --name dvwa --network lab-net vulnerables/web-dvwa
docker run -d --name juice --network lab-net bkimminich/juice-shop

# 공격/분석 컨테이너만 lab-net에 접속
docker run -it --rm --network lab-net kalilinux/kali-rolling bash
```

B.2 egress 차단 (리눅스 호스트)

```
# 브리지 포워딩 기본 차단, 실습망 내부 통신만 허용
iptables -P FORWARD DROP
iptables -A FORWARD -i lab-br -o lab-br -j ACCEPT
iptables -A FORWARD -i lab-br -j DROP          # 외부 egress 원천 차단
```

B.3 호스트 전용 네트워크 (VM)

- VirtualBox: **호스트 전용 어댑터(Host-Only)** 또는 내부 네트워크(Internal)로 실습 세그먼트 분리
- VMware: VMnet host-only, 물리 업무망과 분리
- VLAN: 스위치에서 실습 전용 VLAN ID 할당, 상위 라우터에서 egress 필터

B.4 스냅샷·롤백

```
# VirtualBox
VBoxManage snapshot <vm> take clean-state
VBoxManage snapshot <vm> restore clean-state

# Proxmox VE
vzdump <vmid> --mode snapshot --compress zstd
qm rollback <vmid> clean-state
```

B.5 실습 환경 체크리스트

- [] 실습망이 업무망·인터넷과 물리적/논리적으로 분리되었는가
- [] egress가 기본 차단되고 예외만 허용되는가
- [] 타겟이 합법적 취약 테스트 자산(DVWA·Juice Shop·Metasploitable 등)인가
- [] 시작 전 스냅샷을 생성했는가
- [] 범위 승인서(부록 C.2)에 서명을 받았는가
- [] 로그·산출물이 실습망 외부로 유출되지 않는가
- [] 실습 종료 후 스냅샷 롤백·컨테이너 폐기를 수행했는가

부록 C. 법적 고지 심화 — 법조항·승인 양식·체크리스트

C.1 주요 법조항

관할권	법령	핵심 조항	내용
한국	정보통신망 이용촉진 및 정보보호 등에 관한 법률	제48조(침해행위 금지) · 제49조(비밀 보호) · 제71조(벌칙)	정보통신망 무단 침입·파괴·도용 금지, 위반 시 형사처벌
미국	Computer Fraud and Abuse Act (CFAA)	18 U.S.C. §1030	승인 없이 또는 승인 범위를 초과한 컴퓨터 접근 처벌
영국	Computer Misuse Act 1990	s.1(무단 접근) · s.3(무단 행위)	무단 접근·변조·장애 행위 처벌
EU	AI Act (Regulation 2024/1689)	고위험 AI 의무 · 범용 모델 투명성	AI 제공·배포자 의무 부과
미국	Export Administration Regulations (EAR)	암호·사이버 보안 항목 통제	오픈웨이트 모델·공세 도구의 수출·재수출 통제 가능성
중국	생성형 AI 서비스 관리 잠정 조치 (CAC, 2023)	콘텐츠 안전·등록 의무	생성AI 제공자의 안전·콘텐츠 관리 의무

C.2 침투 테스트 범위 승인 양식 템플릿

[침투 테스트 범위 승인서 (Scope Authorization)]

1. 의뢰자(조직명·부서): _____
2. 수행자(팀·개인): _____
3. 대상 자산 (IP/도메인/시스템, 정확히 기재):
- _____
4. 허용 기법: 정찰() 스캔() 익스플로잇() 사회공학()
- 세부 제한: _____
5. 금지 행위: DoS/DDoS() 제3자 자산 접근()
데이터 유출·변조() 랜섬웨어 등 파괴적 행위()
6. 기간: YYYY-MM-DD HH:MM ~ YYYY-MM-DD HH:MM
7. 비상 연락처(24/7): _____
8. 서명: 의뢰자() 수행자() 법무/정보보호()

※ 이 양식은 참고 템플릿이며, 관할 법령·조직 정책에 맞게 법무 검토를 거쳐 사용한다.

C.3 실습 전 법적 승인 체크리스트

- [] 대상 시스템에 대한 소유권·운영권·승인권 확인했다
- [] 서면 범위 승인서에 서명을 받았다(구두 승인 불충분)
- [] 승인 범위를 벗어나는 IP·도메인은 타겟에서 제외했다
- [] 테스트가 제3자 서비스(클라우드·ISP) 이용약관에 저촉되지 않는지 확인했다
- [] 산출물(스크린샷·로그) 보관·공유 방법을 승인서에 명시했다
- [] 위반 시 즉시 중단 절차와 보고 경로를 사전 합의했다

부록 D. 윤리적 의사결정 프레임워크

이 지식을 어디에 사용할 것인가 — 실습 전에 다섯 가지 질문을 스스로에게 던진다.

1. **목적** — 방어 역량 강화·교육·합법적 연구인가? (공격적 이익·보복이 아닌가)
2. **대상** — 명시적으로 승인된 자산인가? (승인 범위를 넘어서지 않는가)
3. **범위** — 최소 필요 원칙을 지켰는가? (목적 달성에 필요한 만큼만)
4. **영향** — 무고한 제3자·사회에 피해 가능성은 없는가?
5. **책임** — 기록을 남기고, 요청 시 보고·설명할 수 있는가?

다섯 질문 중 하나라도 "아니오"라면 **중단한다**. 판단이 어렵다면 동료·법무와 상의한다.

심연을 바라볼 때 그 심연에 빠져서는 안 된다.

부록 E. 벤치마크 방법론 투명성 표

본 문서에 인용된 벤치마크의 평가 주체·시기·방법론·표본을 정리한다. **자체 평가(self-reported)**는 낙관 편향을 전제로 제3자 평가를 우선 신뢰한다.

벤치마크	평가 주체	평가 유형	방법론 요약	표본 크기
ExploitBench (V8)	Anthropic (공개 평가)	제3자	에이전트 자율 익스플로잇 시도·성공 측정	410 시도
ExploitBench (V8)	UK AISI / CAISI	제3자	41개 V8 취약점 대상 교차 평가	41 취약점
CyberGym	Abliteration.ai	자체 평가	OSS-Fuzz 버그 대상 pass@1	1,507개 버그 (188개 프로젝트)
Terminal-Bench 4.0	Abliteration.ai	자체 평가	터미널 과제 완수율	미공개
ExploitGym (2h)	Abliteration.ai	자체 평가	2시간 제한 익스플로잇	869 태스크
TLO 32단계 기업망 시뮬레이션	(평가 주체 미공개)	미상	다단계 공격 단계 도달 수	32단계
Arbitrary Code Execution	UK AISI / CAISI	제3자	임의 코드 실행 성공 여부	41 태스크
익스플로잇 스위트 (36)	Moonshot AI	자체 평가	자체 구성 36 태스크 해결률	36 태스크

독립 재현: 공개된 독립 재현 결과는 아직 확인되지 않았다. 조직은 (1) 부록 B의 격리 환경에서, (2) 동일 표본·동일 프롬프트로, (3) 자체 재현한 뒤 의사결정에 사용해야 한다. 자체 평가 수치의 독립 검증 없이 인용하지 않는다.

부록 F. 탐지 룰 실측 및 LLM 판정 우회 대응

F.1 탐지 룰 실측 프레임워크

Sigma·YARA·Zeek 룰은 배포 전 반드시 **오탐률(FP)·미탐률(FN)** 을 실측한다. 측정 절차는 다음과 같다.

1. 정상 트래픽·로그 코퍼스($N \geq 10$ 만)를 7일 이상 수집
2. 공격 시뮬레이션(레시피 1~7)으로 양성 샘플($N \geq 100$) 생성
3. 룰을 두 코퍼스에 적용 → TP/FP/FN 집계
4. $FP > 0.1\%$ 또는 $FN > 1\%$ 룰은 튜닝 후 재측정

아래는 개념 검증용 **예시 참고치**다. 수치는 환경 의존적이므로 배포 환경에서 자체 재측정이 필수다.

룰	테스트 환경	표본	오탐률(FP)	미탐률(FN)	비고
Sigma: 비인가 LLM 추론 서버	Windows 11 워크스테이션 50대	프로세스 생성 10만 건	0.2% (예시)	0% (예시)	승인 GPU 노드 화이트리스트 필수
Zeek: LLM API egress	사내망 미러 7일	HTTP 120만 건	0.01% (예시)	—	내부 정상 LLM 사용 부서 화이트리스트 필요
YARA: LLM 산출물 시그니처	PoC 200개 / 정상 코드 5,000개	5,200 파일	0.5% (예시)	8% (예시)	변종 대응 한계 — 정적 탐지의 보조 수단으로만 운용

F.2 LLM 판정 우회 기법과 대응

"LLM 판정도 우회될 수 있다"(10.6.4 원칙 3)는 구체적으로 다음과 같은 경로로 현실화된다.

우회 기법	공격 경로	대응 통제
로그 인젝션	판정 전 로그에 가짜 정상 시퀀스 주입	판정 전 로그 무결성 해시 검증, 수집 경로 이원화
프롬프트 인젝션	로그 속 악성 지시로 판정 조작	지시-데이터 분리, 로그 이스케이프·샌드박싱
적대적 섭동	판정 회피용 로그 미세 변조	결정론적 룰(Sigma/YARA) 병행, 앙상블 교차검증
데이터 포이즈닝	정상 베이스라인 오염	베이스라인 버전 관리·무결성 서명, 공급망 검증
문맥 혼동	이중용도 문맥으로 오탐 유도	판정 근거 필수 저장, 휴먼 리뷰 병행
모델 치환·거부 제거	판정 모델 자체에 대한 공격	모델 가중치 해시 검증, 판정 모델 접근 통제·격리

핵심: LLM 판정은 "1차 분류"일 뿐 "결정"이 아니다. 자동 차단은 결정론적 룰의 교차 확인 이후에만 수행하고, 모든 판정에 근거를 남긴다.

부록 G. 용어집 (Glossary)

- **Abliteration (애블리테이션)** — 모델 가중치에서 거부 응답을 유도하는 방향 벡터를 식별·제거하는 사후 가공 기법. / A post-hoc technique that identifies and removes the "refusal direction" from model weights, drastically reducing refusal rates.
- **MoE (전문가 혼합, Mixture of Experts)** — 다수의 하위 네트워크(전문가) 중 일부만 토큰마다 활성화되는 아키텍처. / An architecture where only a subset of sub-networks (experts) is activated per token.
- **활성 파라미터 (Active Parameters)** — MoE 모델에서 추론 시 실제로 연산에 참여하는 파라미터 수. / The parameters actually used in a forward pass of an MoE model.
- **양자화 (Quantization)** — 가중치·활성화 정밀도를 낮춰(FP8·INT4 등) 메모리와 연산을 줄이는 기법. / Reducing numerical precision of weights/activations to cut memory and compute.
- **NVFP4** — NVIDIA GPU 네이티브 4비트 부동소수점 형식. / NVIDIA's native 4-bit floating-point format.
- **MXFP4 / MXFP8** — OCP 표준 마이크로스케일링 부동소수점 형식(4/8비트). / OCP standard microscaling floating-point formats.
- **FP8** — 8비트 부동소수점 형식. / 8-bit floating-point format.
- **EXL3** — 엑스라마 기반 3비트 양자화 형식. / A 3-bit quantization format based on ExLlama.
- **GGUF** — llama.cpp 계열이 사용하는 단일 파일 모델 형식. / A single-file model format used by llama.cpp.
- **추측 디코딩 (Speculative Decoding)** — 소형 모델이 초안을 생성하고 대형 모델이 검증해 처리량을 높이는 기법. / A small draft model generates tokens that a large model verifies, increasing throughput.
- **KV 캐시 (KV Cache)** — 어텐션 계산 재사용을 위해 키·값을 저장하는 캐시. / Cached key/value tensors to avoid recomputation in attention.
- **텐서 병렬 (Tensor Parallelism)** — 모델 가중치를 여러 GPU에 분산하는 병렬화. / Splitting model weights across multiple GPUs.
- **컨텍스트 윈도우 (Context Window)** — 모델이 한 번에 처리할 수 있는 토큰 수. / The number of tokens a model can process at once.
- **거부 응답 (Refusal)** — 모델이 유해 요청에 응답을 거부하는 안전 행동. / The safety behavior where a model declines harmful requests.
- **탈옥 (Jailbreak)** — 프롬프트 조작으로 거부 안전장치를 우회하는 기법. / Prompt manipulation that bypasses refusal safeguards.
- **프롬프트 인젝션 (Prompt Injection)** — 외부 입력에 악성 지시를 숨겨 모델 행동을 조작하는 공격. / Hiding malicious instructions in external inputs to manipulate model behavior.
- **모델 포이즈닝 (Model Poisoning)** — 학습 데이터·가중치에 악성 패턴을 심는 공격. / Injecting malicious patterns into training data or weights.
- **MCP (모델 컨텍스트 프로토콜, Model Context Protocol)** — LLM과 외부 도구·데이터를 연결하는 개방형 프로토콜. / An open protocol connecting LLMs to external tools and data.
- **에이전트 (Agent) / 오케스트레이션 (Orchestration)** — LLM이 도구를 호출하며 작업을 수행하는 구성 / 다수 에이전트의 계획·조정. / LLM-driven tool use / planning and coordinating multiple agents.
- **C2 (커맨드 앤드 컨트롤, Command and Control)** — 공격자가 감염 자산을 원격 제어하는 인프라·채널. / Infrastructure and channels for remotely controlling compromised assets.

- **egress (이그레스)** — 내부에서 외부로 나가는 네트워크 트래픽. / Outbound network traffic from inside to outside.
- **SIEM / SOAR** — 로그 수집·상관 분석 플랫폼 / 탐지 후 대응을 자동화하는 플랫폼. / Log correlation platform / response automation platform.
- **EDR / XDR** — 엔드포인트 탐지·대응 / 여러 도메인을 아우르는 확장 탐지·대응. / Endpoint detection and response / extended detection and response.
- **eBPF** — 커널 내부를 안전하게 관찰·확장하는 기술(Falco·Tetragon의 기반). / A technology for safely observing and extending the kernel (basis of Falco/Tetragon).
- **Sigma / YARA** — SIEM용 탐지 룰 포맷 / 파일·메모리 패턴 매칭 룰. / Detection rule format for SIEMs / pattern-matching rules for files.
- **Zeek / Suricata** — 네트워크 트래픽 분석 프레임워크 / 오픈소스 NIDS·IPS. / Network traffic analysis framework / open-source NIDS/IPS.
- **JA3/JA4** — TLS 핸드셰이크 기반 클라이언트 지문 방식. / TLS handshake-based client fingerprinting.
- **IOC / TTP** — 침해지표(IP·해시 등) / 공격자의 전술·기법·절차. / Indicators of compromise / tactics, techniques, and procedures.
- **CTI (사이버 위협 인텔리전스)** — 위협에 대한 수집·분석·배포 지식. / Knowledge about threats: collection, analysis, dissemination.
- **레드팀/블루팀/퍼플팀** — 공격자 역할/방어자 역할/양자 협업 팀. / Offensive role / defensive role / collaborative role.
- **오탐(FP)·미탐(FN)** — 정상을 공격으로 오판하는 비율 / 공격을 놓치는 비율. / False positive rate / false negative rate.
- **SBOM (소프트웨어 자재 명세서)** — 소프트웨어 구성요소·의존성 목록. / A list of software components and dependencies.
- **WORM 저장소** — 한 번 기록하면 수정·삭제가 불가능한 저장소. / Write-once-read-many storage that cannot be modified.
- **허니팟 (Honeytrap)** — 공격자를 유인해 행동을 관찰하는 미끼 시스템. / A decoy system designed to lure and observe attackers.
- **의존성 혼동 (Dependency Confusion)** — 공개 레지스트리에 동명 패키지를 올려 내부 의존성을 탈취하는 공급망 공격. / A supply-chain attack uploading same-named packages to public registries.
- **제로데이 (Zero-day)** — 패치가 존재하지 않는 알려지지 않은 취약점. / An unknown vulnerability with no available patch.
- **베이스라인 (Baseline)** — 이상 탐지의 기준이 되는 정상 행동 프로파일. / The normal behavior profile used as the reference for anomaly detection.

"우리의 잔치는 이제 끝났다."

"Our revels now are ended."

— 윌리엄 셰익스피어, 《템페스트》 4막 1장 (The Tempest, Act IV, Scene I)

Open-Weight LLM Threat Cook Book — v1.7 · 2026.10.05